01 / RVU PRACTICAL RESOURCES

SECURITY REPORT PLAYBOOK

01

Security report playbook

A clear test. Evidence others can reproduce.

Use your actual test evidence to complete each section and remove irrelevant sections. The example is educational, not a claim about a real service.

01

Understand

Identify expected and observed behavior

02

Verify

Connect each claim to test evidence

03

Write

Make the result reproducible

ENGLISH EDITION

GUIDE + WORKSHEET / 04 PAGES

01 / METHOD / REFERENCE

Write a report others can review

Organize behavior, steps and impact, then review your evidence

01 Title

Describe the flaw, affected feature and demonstrated impact.

Example wording: Missing order ownership validation allows one test account to view another test account's order.

02 Summary

Describe expected behavior, observed behavior and prerequisites, including the account role required.

03 Scope and environment

Identify the asset, endpoint, HTTP method, role, test time and application version if known. Label accounts you own Account A and Account B. Remove cookies, tokens and personal information from shared evidence.

04 Reproduction steps

1. Prepare the required accounts and resources in the authorized environment.
2. Perform the normal action as the resource owner and capture a baseline.
3. Change one variable using the other account's session, identifying the requested resource.
4. Compare the expected and actual outcomes.
5. Verify returned data or stored server-side state; HTTP 200 alone proves nothing.

01 / REVIEW / NEXT STEPS

Evidence, impact and final review

Organize behavior, steps and impact, then review your evidence

05 Evidence

For each relevant step, include the request, meaningful response excerpt and acting account. Establish resource ownership. Add a readable screenshot or short video when useful; video should complement written reproduction steps.

06 Impact and limits

State the access or state change you demonstrated. Separate evidence from hypotheses. Do not generalize a limited test to all users or invent financial loss.

07 Remediation

Address the underlying cause. For the order ownership example: validate server-side permission for the resource on every sensitive action and add regression coverage.

08 Before submitting

- [ ] The asset and testing are in scope.
- [ ] Another person can reproduce the steps.
- [ ] Expected and actual outcomes are explicit.
- [ ] Secrets and private data are removed from shared evidence.
- [ ] Impact and severity follow the evidence.
- [ ] The title and summary describe this specific finding.

01 / PRACTICE / WORKSHEET

From a test to a reviewable draft

Organize behavior, steps and impact, then review your evidence

Asset and endpoint

Accounts and resources

Account A / Account B / Owner

Title and summary

Flaw + affected feature + demonstrated impact + prerequisites

Reproduction steps

Setup, baseline, controlled change, verified result

Expected / actual

Impact and evidence limits

Evidence and remediation

Connect evidence to steps and address the underlying cause

Final review

Can someone else reproduce it? Have you removed secrets? Does impact follow the evidence? HTTP 200 alone does not prove a flaw.